

Week 2 – Theory Notes

1. Alert Priority Levels

Introduction

In a Security Operations Center (SOC), thousands of alerts may be generated every day. It is impossible for analysts to investigate every alert immediately. Therefore, alerts are assigned priority levels based on their severity, impact, likelihood of exploitation, and business risk. Proper prioritization ensures that critical threats are handled first while less severe events are monitored accordingly.

What is Alert Prioritization?

Alert prioritization is the process of assigning importance to security alerts based on the potential damage they can cause to an organization's systems, networks, and data.

The purpose of alert prioritization is to:

- Reduce alert fatigue
- Improve incident response time
- Focus analyst attention on critical threats
- Minimize business impact
- Improve SOC efficiency

Priority Levels

1. Critical Priority

Critical alerts indicate active attacks or severe security incidents that require immediate action.

Characteristics:

- Active compromise detected
- Data breach in progress
- Ransomware execution
- Domain administrator compromise
- Critical server under attack

Examples:

- Log4Shell exploitation detected
- Ransomware encrypting files
- Unauthorized root access
- Active data exfiltration

Response Time:

Immediate (within minutes)

2. High Priority

High-priority alerts indicate serious threats that could cause significant damage if left unresolved.

Characteristics:

- Unauthorized privileged access
- Malware infection
- Multiple failed authentication attempts
- Exploitation attempts

Examples:

- Privilege escalation detected
- Malware execution on endpoint
- Suspicious PowerShell activity
- Credential dumping attempt

Response Time:

Within one hour

3. Medium Priority

Medium-priority alerts indicate suspicious activities requiring investigation.

Characteristics:

- Unusual user behavior
- Network scanning
- Repeated login failures
- Suspicious downloads

Examples:

- Port scanning activity
- Failed login attempts
- Unusual file access
- Unknown software installation

Response Time:

Within several hours

4. Low Priority

Low-priority alerts usually indicate informational events or minor security concerns.

Characteristics:

- Minimal impact
- No immediate threat
- Monitoring required

Examples:

- Single failed login attempt
- New device connected
- Routine configuration changes

Response Time:

As resources permit

Factors Affecting Alert Priority

Asset Criticality

The importance of the affected system influences alert priority.

Examples:

- Production database server = High priority
- Testing machine = Lower priority

Exploit Availability

If public exploits exist, the alert receives higher priority.

Examples:

- Log4Shell vulnerability
- EternalBlue exploit

Business Impact

Alerts affecting business operations are prioritized higher.

Examples:

- Financial system compromise

- Customer data exposure
- Service outage

Common Risk Scoring Systems

CVSS (Common Vulnerability Scoring System)

CVSS provides standardized severity ratings.

Score Range Severity

0.0 – 3.9	Low
4.0 – 6.9	Medium
7.0 – 8.9	High
9.0 – 10.0	Critical

Example:

Log4Shell (CVE-2021-44228) has a CVSS score of 10.0 and is considered Critical.

Importance of Alert Prioritization

- Faster incident response
- Better resource utilization
- Reduced operational risk
- Improved threat management
- Enhanced business continuity

Conclusion

Alert prioritization is one of the most important responsibilities of SOC analysts. By understanding severity levels, asset criticality, exploit availability, and business impact, analysts can efficiently identify and respond to threats before significant damage occurs.

2. Incident Classification

Introduction

Incident classification is the process of categorizing security incidents into predefined groups based on their nature, behavior, and impact. Proper classification helps organizations investigate incidents effectively and maintain consistent reporting standards.

Purpose of Incident Classification

The objectives include:

- Standardized reporting
- Faster investigations
- Better threat analysis
- Improved communication
- Enhanced incident tracking

Common Incident Categories

Malware Incident

Occurs when malicious software infects systems.

Examples:

- Ransomware
- Trojan
- Worm
- Spyware

Phishing Incident

Attempts to trick users into revealing sensitive information.

Examples:

- Fake login pages
- Email scams
- Credential theft

Denial of Service (DoS/DDoS)

Attempts to overwhelm systems and make services unavailable.

Examples:

- SYN Flood
- UDP Flood
- HTTP Flood

Insider Threat

Security incidents caused by trusted individuals.

Examples:

- Unauthorized file access
- Data theft by employees
- Privilege misuse

Data Exfiltration

Unauthorized transfer of sensitive data.

Examples:

- Customer database theft
- Intellectual property leakage

Unauthorized Access

Attackers gain access without permission.

Examples:

- Stolen credentials
- Password spraying
- Brute force attacks

MITRE ATT&CK Framework

MITRE ATT&CK is widely used for incident classification.

Example Mapping

Incident	Technique ID
Phishing Email	T1566
Command Execution	T1059
Credential Dumping	T1003
Data Exfiltration	T1041

VERIS Framework

VERIS (Vocabulary for Event Recording and Incident Sharing) provides a structured method for documenting incidents.

Components include:

- Threat Actor
- Action
- Asset
- Impact

ENISA Incident Taxonomy

ENISA classifies incidents based on:

- Malware
- Intrusion
- Availability
- Information Gathering
- Information Security Breach

Incident Metadata

Important metadata includes:

- Timestamp
- Source IP
- Destination IP
- File Hashes
- User Account
- Hostname
- Affected System

Importance of Incident Classification

- Consistent investigations
- Improved reporting
- Faster remediation
- Better threat intelligence correlation

Conclusion

Incident classification enables organizations to understand, investigate, and manage security incidents systematically. Frameworks such as MITRE ATT&CK, VERIS, and ENISA provide structured methods for classifying threats and improving SOC effectiveness.

3. Basic Incident Response

Introduction

Incident Response (IR) is a structured process used to identify, investigate, contain, eradicate, and recover from cybersecurity incidents. Effective incident response minimizes damage and ensures rapid restoration of business operations.

Objectives of Incident Response

- Minimize business impact
- Protect sensitive data
- Restore services quickly
- Prevent future incidents
- Preserve evidence

NIST Incident Response Lifecycle

1. Preparation

Preparation involves establishing the necessary tools, procedures, and personnel before incidents occur.

Activities:

- Create response plans
- Train SOC analysts
- Deploy monitoring tools
- Develop communication plans

2. Identification

The organization identifies and confirms the security incident.

Activities:

- Monitor alerts

- Analyze logs
- Verify indicators of compromise
- Determine severity

Example:

Wazuh generates an alert indicating ransomware behavior.

3. Containment

Containment prevents the incident from spreading.

Activities:

- Disconnect affected systems
- Block malicious IP addresses
- Disable compromised accounts

Example:

An infected workstation is isolated from the network.

4. Eradication

The root cause of the incident is removed.

Activities:

- Delete malware
- Patch vulnerabilities
- Remove unauthorized accounts

Example:

Removing ransomware files from the endpoint.

5. Recovery

Systems are restored to normal operations.

Activities:

- Restore backups
- Validate system functionality
- Monitor for recurring threats

Example:

Restoring encrypted files from backup storage.

6. Lessons Learned

The organization reviews the incident to improve future response.

Activities:

- Conduct post-mortem analysis
- Update playbooks
- Improve security controls

Example:

Implementing MFA after credential compromise.

Evidence Preservation

Proper evidence preservation is essential.

Types of Evidence

Volatile Evidence

- RAM contents
- Running processes
- Active network connections

Non-Volatile Evidence

- Hard drives
- Log files
- Configuration files

Chain of Custody

Chain of custody documents evidence handling.

Information includes:

- Evidence identifier
- Collector name
- Date and time
- Hash values
- Storage location

Communication During Incident Response

Communication should involve:

- SOC Analysts
- Incident Response Team
- Management
- Legal Department
- External Stakeholders

Common Incident Response Tools

Tool	Purpose
Wazuh	SIEM Monitoring
TheHive	Incident Management
Velociraptor	Forensic Collection
FTK Imager	Evidence Acquisition
VirusTotal	IOC Analysis
CrowdSec	Threat Blocking

Benefits of Effective Incident Response

- Reduced downtime
- Faster recovery
- Improved security posture
- Better regulatory compliance
- Reduced financial losses

Conclusion

Incident Response is a critical cybersecurity function that enables organizations to detect, contain, and recover from security incidents efficiently. Following the NIST lifecycle ensures a systematic and effective approach to handling cyber threats.